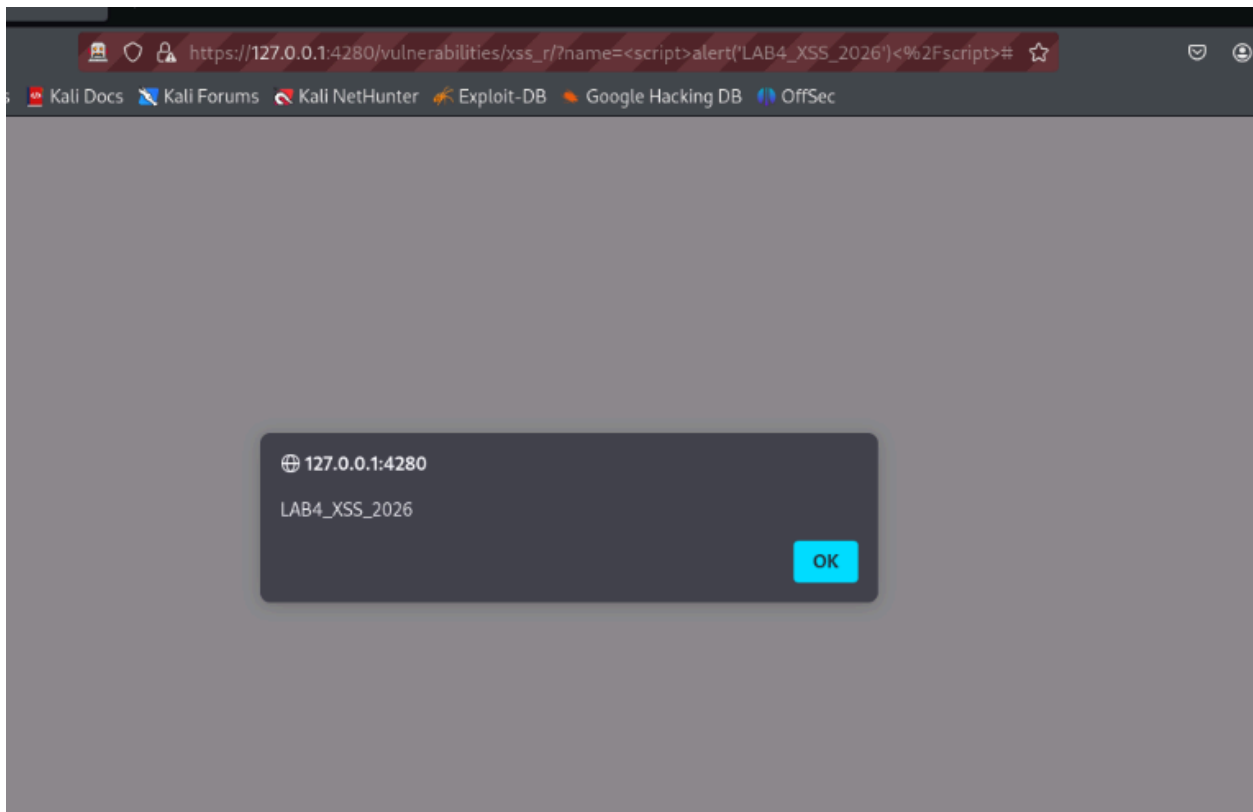


```
habeebah@kali: ~/Lab4
File Actions Edit View Help

(habeebah@kali)~-[~/Lab4]
$ ls
notes requests responses screenshots
(habeebah@kali)~-[~/Lab4]
$ nano ~/Lab4/notes/activity-log.txt
(habeebah@kali)~-[~/Lab4]
$ nano ~/Lab4/notes/activity-log.txt
(habeebah@kali)~-[~/Lab4]
$ <script>alert('LAB4_XSS_2026')</script>
zsh: parse error near `\\n'
(habeebah@kali)~-[~/Lab4]
$ curl -I http://127.0.0.1:4280/phpinfo.php
HTTP/1.1 302 Found
Date: Wed, 02 Sep 2026 19:13:10 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Set-Cookie: security-impossible; path=/; HttpOnly
Set-Cookie: PHPSESSID=199ea8738b762f52de300d88359c665e; expires=Thu, 03 Sep 2026 19:13:11 GMT; Max-Age=86400; path=/; domain=127.0.0.1; HttpOnly; SameSite=Strict
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Set-Cookie: PHPSESSID=c211f0690341194bebe06926c64abd99; expires=Thu, 03 Sep 2026 19:13:11 GMT; Max-Age=86400; path=/; domain=127.0.0.1; HttpOnly; SameSite=Strict
Location: login.php
Content-Type: text/html; charset=UTF-8
(habeebah@kali)~-[~/Lab4]
$ curl -I http://127.0.0.1/
HTTP/1.1 200 OK
Date: Wed, 02 Sep 2026 19:13:21 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Set-Cookie: PHPSESSID=30de1741efa0b5c16e3dcc311fa82caf; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: public
Set-Cookie: showhints=1; path=/; SameSite=Lax
```

I entered `<script>alert('LAB4_XSS_2026')</script>` at lowest security reflected XSS



[Home](#)
[Instructions](#)
[Setup / Reset DB](#)

[Brute Force](#)
[Command Injection](#)
[CSRF](#)
[File Inclusion](#)
[File Upload](#)
[Insecure CAPTCHA](#)
[SQL Injection](#)
[SQL Injection \(Blind\)](#)
[Weak Session IDs](#)
[XSS \(DOM\)](#)
[XSS \(Reflected\)](#)
[XSS \(Stored\)](#)
[CSP Bypass](#)
[JavaScript Attacks](#)
[Authorisation Bypass](#)
[Open HTTP Redirect](#)
[Cryptography](#)
[API](#)

[DVWA Security](#)
[PHP Info](#)
[About](#)

[Logout](#)

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

Hello

More Information

- <https://owasp.org/www-community/attacks/xss/>
- <https://owasp.org/www-community/xss-filter-evasion-cheatsheet>
- https://en.wikipedia.org/wiki/Cross-site_scripting
- <https://www.cisecurity.com/xss-faq.html>
- <https://www.scriptalert1.com/>

Username: admin
 Security Level: Security Level: low
 Locale: en

[View Source](#) [View Help](#)

[Quick Start](#)
[Request](#)
[Response](#)
[Requester](#)

Contexts

Default Context

Sites

http://127.0.0.1:4280

Header: Text

Body: Text

```

GET
http://127.0.0.1:4280/vulnerabilities/xss_r/?name=%3Cscript%3Ealert%28%27LAB4_XSS_2026%27%29%3C%2Fscript%3E HTTP/1.1
host: 127.0.0.1:4280
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: https://127.0.0.1:4280/vulnerabilities/xss_r/
Cookie: security=low; PHPSESSID=7f12bc1bde9588f1150466b077687813
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
        
```

[History](#)
[Search](#)
[Alerts](#)
[Output](#)
[WebSockets](#)

Filter: OFF

Export

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
25	Pr...	02/09/2026, 20:20:58	GET	http://127.0.0.1:4280/favicon.ico	200	OK	2...	1,406 bytes			
26	Pr...	02/09/2026, 20:21:10	GET	http://127.0.0.1:4280/vulnerabilities/xss_r/...	200	OK	1...	4,804 bytes	Medium		Form, Script
27	Pr...	02/09/2026, 20:21:13	GET	http://127.0.0.1:4280/favicon.ico	200	OK	1...	1,406 bytes			
28	Pr...	02/09/2026, 20:21:34	GET	http://127.0.0.1:4280/vulnerabilities/xss_r/	200	OK	1...	4,748 bytes			Form, Script
29	Pr...	02/09/2026, 20:21:40	GET	http://127.0.0.1:4280/vulnerabilities/xss_r/...	200	OK	1...	4,804 bytes			Form, Script

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode Quick Start Request Response Requester

Sites

Contexts

Default Context

Sites

http://127.0.0.1:4280

Header: Text Body: Text

HTTP/1.1 200 OK
Date: Wed, 02 Sep 2026 19:21:40 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
X-XSS-Protection: 0
Vary: Accept-Encoding
Content-Length: 4884
Keep-Alive: timeout=5, max=100

What's your name?
<input type="text" name="name">
<input type="submit" value="Submit">
</p>
</form>
<pre>Hello <script>alert('LAB4_XSS_2026')</script></pre>
</div>

History Search Alerts Output WebSockets

Filter: OFF Export

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp.	Body Highest Alert	Note	Tags
25	Pr...	02/09/2026, 20:20:58	GET	http://127.0.0.1:4280/favicon.ico	200 OK		2...	1,406 bytes			
26	Pr...	02/09/2026, 20:21:10	GET	http://127.0.0.1:4280/vulnerabilities/xss_r/...	200 OK		1...	4,804 bytes	Medium		Form, Script
27	Pr...	02/09/2026, 20:21:13	GET	http://127.0.0.1:4280/favicon.ico	200 OK		1...	1,406 bytes			
28	Pr...	02/09/2026, 20:21:34	GET	http://127.0.0.1:4280/vulnerabilities/xss_r/...	200 OK		1...	4,748 bytes			Form, Script
29	Pr...	02/09/2026, 20:21:40	GET	http://127.0.0.1:4280/vulnerabilities/xss_r/...	200 OK		1...	4,804 bytes			Form, Script

DOM XSS

https://127.0.0.1:4280/vulnerabilities/xss_d/?default=LAB4_XSS_2026

Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

DVWA

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)

Vulnerability: DOM Based Cross Site Scripting (XSS)

Please choose a language:

LAB4_XSS_2026 Select

LAB4_XSS_2026

English
French
Spanish
German

www-community/attacks/xss/
www-community/attacks/DOM Based XSS
tix.com/blog/articles/dom-xss-explained/

127.0.0.1:4280/vulnerabilities/xss_d/default=LAB4_XSS_2026

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

DVWA

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

Vulnerability: DOM Based Cross Site Scripting (XSS)

Please choose a language:
LAB4_XSS_2026 Select

More Information

- <https://owasp.org/www-community/attacks/xss/>
- https://owasp.org/www-community/attacks/DOM_Based_XSS
- <https://www.acunetix.com/blog/articles/dom-xss-explained/>

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application

LAB4_XSS_2026

<div class="vulnerable_code_area">

<p>Please choose a language:</p>

<form name="XSS" method="GET">

<select name="default">

<script></script>

<option value="LAB4_XSS_2026">LAB4_XSS_2026</option>

<option value="" disabled="disabled">----</option>

Filter Styles

input, textarea, select { font: 100% arial,sans-serif;

https://127.0.0.1:4280/vulnerabilities/xss_s/

Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

DVWA

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript Attacks

Authorisation Bypass

Vulnerability: Stored Cross Site Scripting (XSS)

Name *

Message *

Sign Guestbook Clear Guestbook

Name: test

Message: This is a test comment.

Name: hello

Message:

More Information

- <https://owasp.org/www-community/attacks/xss>
- <https://owasp.org/www-community/xss-filter-evasion-cheatsheet>
- https://en.wikipedia.org/wiki/Cross-site_scripting
- <https://www.cgisecurity.com/xss-faq.html>
- <https://www.scriptalert1.com/>

home

instructions

setup / Reset DB

brute Force

command Injection

SRF

le Inclusion

le Upload

secure CAPTCHA

QL Injection

QL Injection (Blind)

eak Session IDs

SS (DOM)

SS (Reflected)

SS (Stored)

SP Bypass

vaScript Attacks

uthorisation Bypass

https://127.0.0.1:4280/vulnerabilities/xss_s/

Kali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSec

DVWA

Vulnerability: Stored Cross Site Scripting (XSS)

Name *

Message *

Sign Guestbook

Clear Guestbook

Name: test

Message: This is a test comment.

Name: hello

Message:

Name: LAB4_XSS_2

Message: LAB4_XSS_2026

More Information

- <https://owasp.org/www-community/attacks/xss>
- <https://owasp.org/www-community/xss-filter-evasion-cheatsheet>
- https://en.wikipedia.org/wiki/Cross-site_scripting
- <https://www.cgisecurity.com/xss-faq.html>
- <https://www.scriptalert1.com/>



- Home
- Instructions
- Setup / Reset DB
- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)**
- XSS (Stored)
- CSP Bypass
- JavaScript Attacks
- Authorisation Bypass
- Open HTTP Redirect
- Cryptography
- API
- DVWA Security
- PHP Info
- About
- Logout

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

Hello >

More Information

- <https://owasp.org/www-community/attacks/xss/>
- <https://owasp.org/www-community/xss-filter-evasion-cheatsheet>
- https://en.wikipedia.org/wiki/Cross-site_scripting
- <https://www.cgisecurity.com/xss-faq.html>
- <https://www.scriptalert.com/>

Username: admin

Security Level: Security Level: High

[View Source](#) [View Help](#)



- Home
- Instructions
- Setup / Reset DB
- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)**
- XSS (Stored)
- CSP Bypass
- JavaScript Attacks
- Authorisation Bypass
- Open HTTP Redirect
- Cryptography
- API
- DVWA Security
- PHP Info
- About
- Logout

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

Hello <script>alert('LAB4_XSS_2026')</script>

More Information

- <https://owasp.org/www-community/attacks/xss/>
- <https://owasp.org/www-community/xss-filter-evasion-cheatsheet>
- https://en.wikipedia.org/wiki/Cross-site_scripting
- <https://www.cgisecurity.com/xss-faq.html>
- <https://www.scribd.com/>

Username: admin
Security Level: Security Level: impossible
Locale: en

[View Source](#) [View Help](#)



- Home
- Instructions
- Setup / Reset DB
- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)**
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript Attacks
- Authorisation Bypass
- Open HTTP Redirect
- Cryptography
- API
- DVWA Security
- PHP Info
- About
- Logout

Vulnerability: DOM Based Cross Site Scripting (XSS)

Please choose a language:

LAB4_XSS_2026

LAB4_XSS_2026

English

French

Spanish

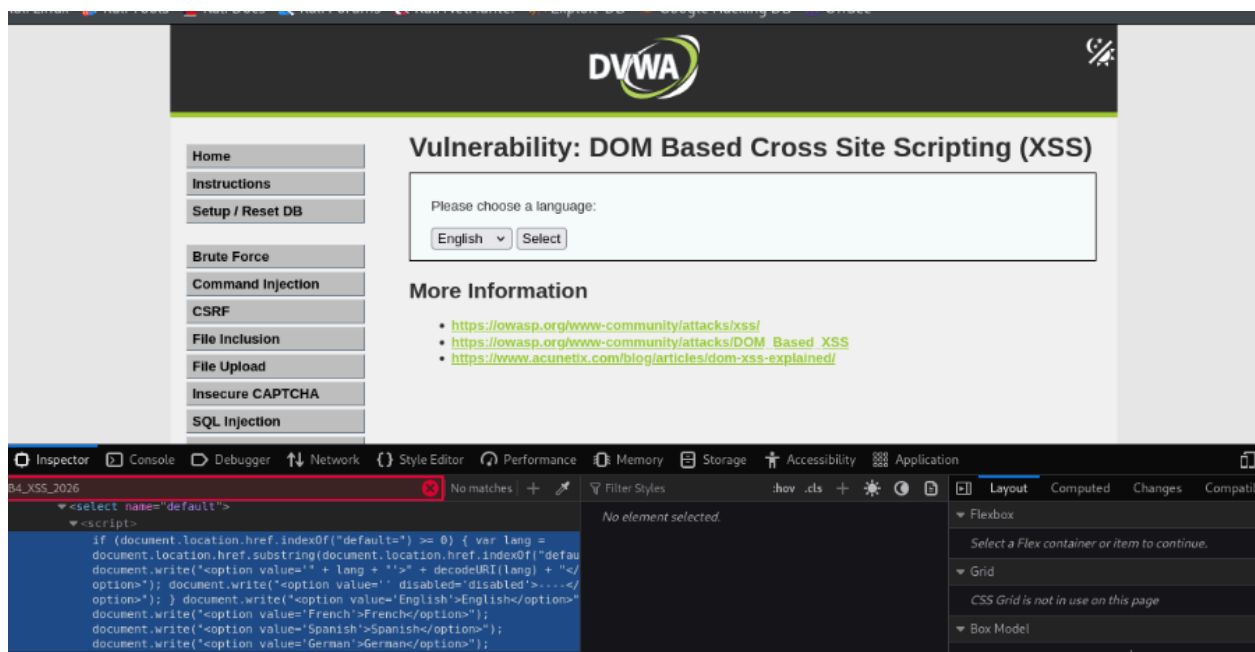
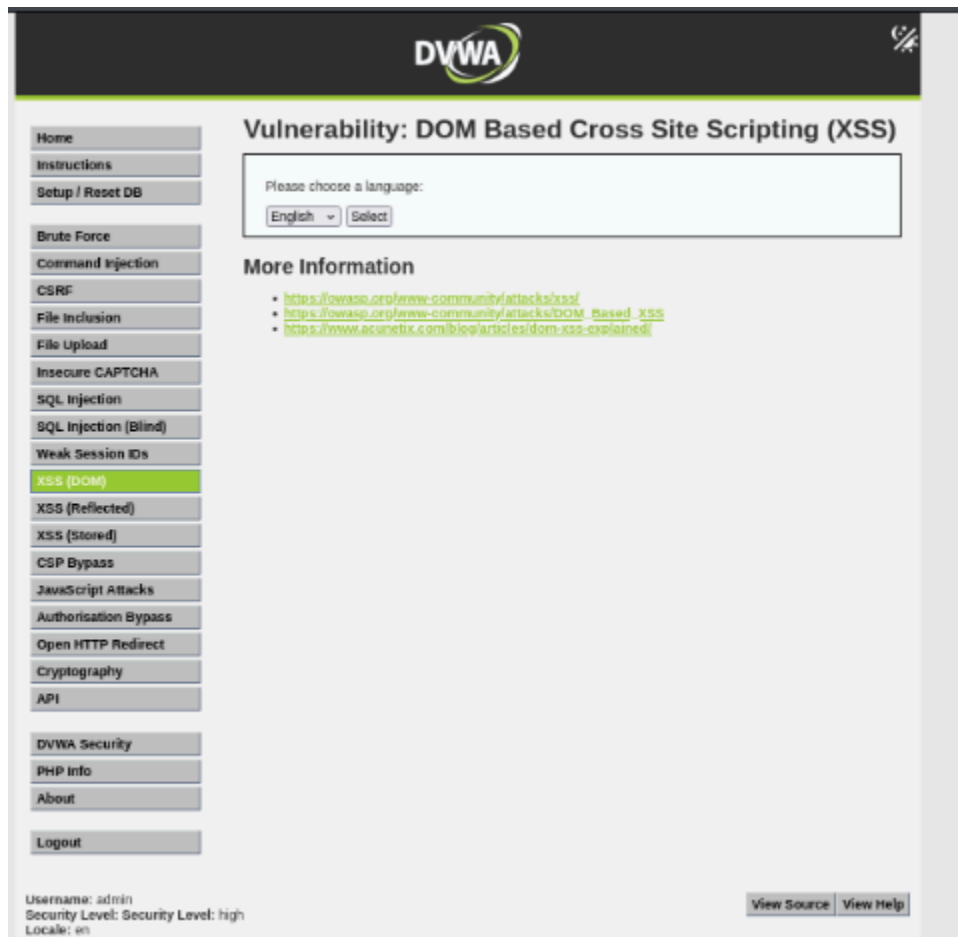
German

www-community/attacks/xss/
www-community/attacks/DOM_Based_XSS/
stix.com/blog/articles/dom-xss-explained/

Username: admin
Security Level: Security Level: impossible
Locale: en

[View Source](#) [View Help](#)

AT high sec, it returned the normal page, the marker didn't show



Request	Response
Method Text  Send GET http://127.0.0.1:4280/vulnerabilities/xss_d/?default=LAB4_XSS_2026 HTTP/1.1 host: 127.0.0.1:4280 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Language: en-US,en;q=0.5 Connection: keep-alive Cookie: security=high; PHPSESSID=63287f272b16128780543d31afcfc95a Upgrade-Insecure-Requests: 1 Sec-Fetch-Dest: document Sec-Fetch-Mode: navigate Sec-Fetch-Site: none Sec-Fetch-User: ?1 Priority: u=0, i	

Request	Response
Header: Text Body: Text  Send	



- Home
- Instructions
- Setup / Reset DB
- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)**
- CSP Bypass
- JavaScript Attacks
- Authorisation Bypass
- Open HTTP Redirect
- Cryptography
- API
- DVWA Security
- PHP Info
- About
- Logout

Vulnerability: Stored Cross Site Scripting (XSS)

Name *

Message *

[Sign Guestbook](#) [Clear Guestbook](#)

Name: test
Message: This is a test comment.

Name: hello
Message:

Name: LAB4_XSS_2
Message: LAB4_XSS_2026

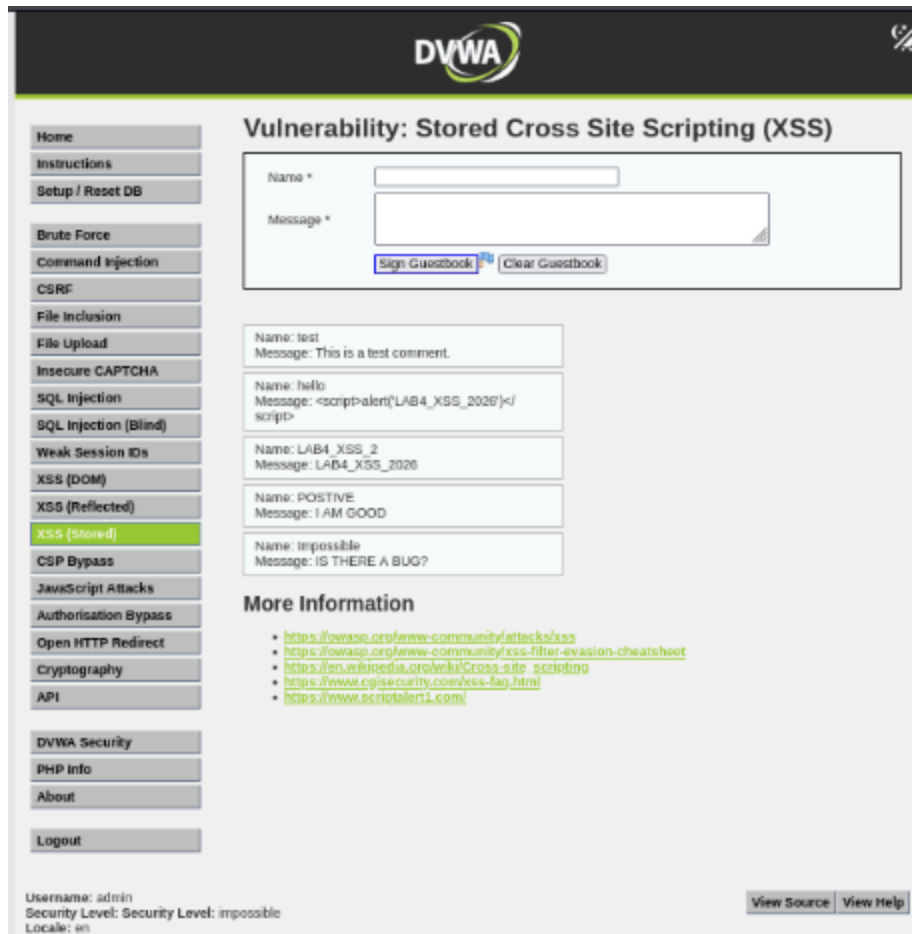
Name: POSTVE
Message: I AM GOOD

More Information

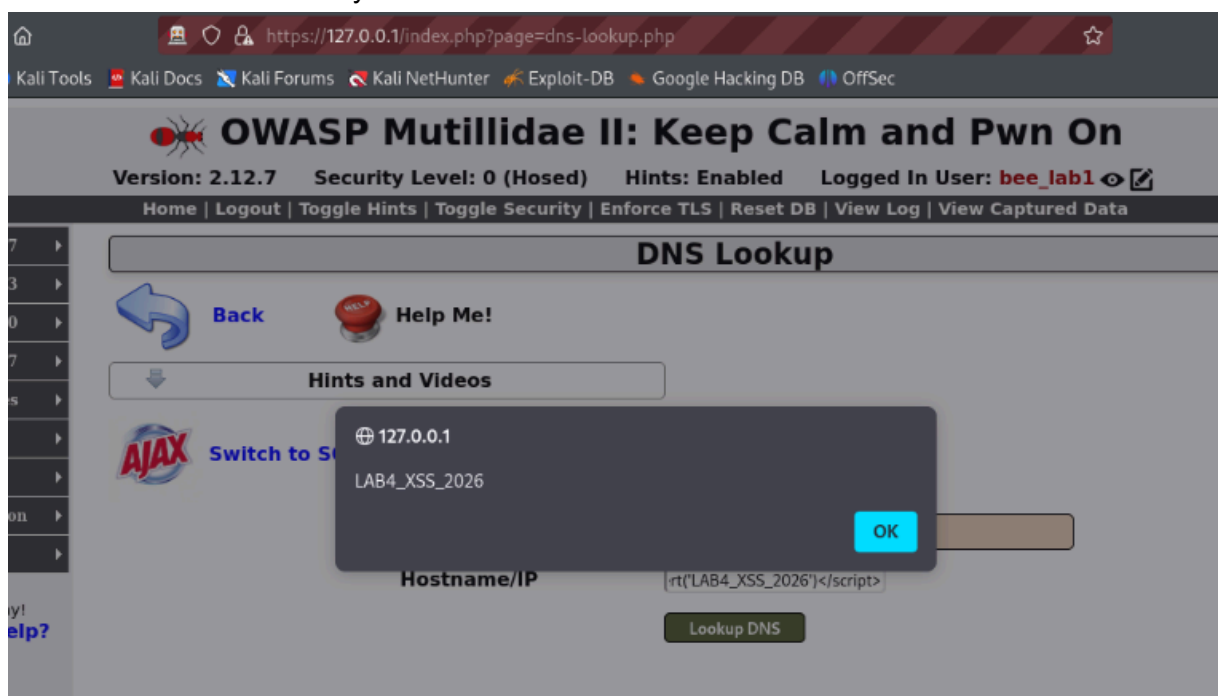
- <https://owasp.org/www-community/attacks/xss>
- <https://owasp.org/www-community/xss-filter-evasion-cheatsheet>
- https://en.wikipedia.org/wiki/Cross-site_scripting
- <https://www.cgisecurity.com/css-faq.html>
- <https://www.scriptalert1.com/>

Username: admin
Security Level: Security Level: high
Locale: en

[View Source](#) [View Help](#)



Multillidae at lowest security reflected XSS



At the highest sec



OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.12.7 Security Level: 5 (Secure) Hints: Disabled Logged In User: **bee_lab1**  

[Home](#) | [Logout](#) | [Toggle Security](#) | [Enforce TLS](#) | [Reset DB](#) | [View Log](#) | [View Captured Data](#)

DNS Lookup

 [Back](#)

 **Help Me!**

127.0.0.1

Malicious characters are not allowed.

Don't listen to security people. Everyone knows if we just filter dangerous characters, injection is not possible.

We use JavaScript defenses combined with filtering technology.

Both are such great defenses that you are stopped in your tracks.

OK

 [Switch to S](#)



OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.12.7 Security Level: 0 (Hosed) Hints: Enabled Logged In User: **bee_lab1**  

[Home](#) | [Logout](#) | [Toggle Hints](#) | [Toggle Security](#) | [Enforce TLS](#) | [Reset DB](#) | [View Log](#) | [View Captured Data](#)

Error Message

Failure is always an option

Line	237
Code	0
File	/var/www/mutillidae/classes/MySQLHandler.php
Message	<pre>/var/www/mutillidae/classes/MySQLHandler.php on line 229: You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near 'LAB4_XSS_2026')', now())' at line 1 Query: INSERT INTO blogs_table(blogger_name, comment, date) VALUES ('bee_lab1', '<script>alert('LAB4_XSS_2026')</script>', now()) (1064) [mysqli_sql_exception]</pre>

#0 /var/www/mutillidae/classes/MySQLHandler.php(327): MySQLHandler->doExecuteQuery('\r\n\t\t\tINSERT INT...') #1 /var/www/mutillidae/classes/SQLQueryHandler.php(234): MySQLHandler->executeQuery('\r\n\t\t\tINSERT INT...') #2 /var/www/mutillidae/add-to-your-blog.php(141): SQLQueryHandler->insertBlogRecord('bee_lab1', '

Welcome To The Blog

 [Back](#)

 **Help Me!**

 [Hints and Videos](#)

Add New Blog Entry

 [View Blogs](#)

Save Blog Entry

View Blogs

0 Current Blog Entries

Name	Date	Comment
------	------	---------

CSRF Protection Information

Posted Token:
(Validation not performed)

Expected Token For This Request:

Token Passed By User For This Request:

New Token For Next Request:

Token Stored in Session:

Browser: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0

PHP Version: 8.5.9

For non-relected (psw generator)
First is a real user

127.0.0.1/index.php?page= x

https://127.0.0.1/index.php?page=password-generator.php&username=LAB4_DOM_2026

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.12.7 Security Level: 0 (Hosed) Hints: Enabled Logged In User: **bee_lab1**  

[Home](#) | [Logout](#) | [Toggle Hints](#) | [Toggle Security](#) | [Enforce TLS](#) | [Reset DB](#) | [View Log](#) | [View Captured Data](#)

Password Generator

 [Back](#)  [Help Me!](#)

 [Hints and Videos](#)

Password Generator

Making strong passwords is important.
Click the button below to generate a password.

This password is for LAB4_DOM_2026

Password: **c6twEoG3WrUaAE3sqhX7kc3vcKuLHvK**

[Generate Password](#)

Second is scripted in

https://127.0.0.1/index.php?page=password-generator.php&username=bee_lab1

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.12.7 Security Level: 0 (Hosed) Hints: Enabled Logged In User: **bee_lab1**  

[Home](#) | [Logout](#) | [Toggle Hints](#) | [Toggle Security](#) | [Enforce TLS](#) | [Reset DB](#) | [View Log](#) | [View Captured Data](#)

Password Generator

 [Back](#)  [Help Me!](#)

 [Hints and Videos](#)

Password Generator

Making strong passwords is important.
Click the button below to generate a password.

This password is for bee_lab1

Password: **uX5Wknc2TJO0QVr5gRQisOJDIdKKah**

[Generate Password](#)

127.0.0.1/index.php?page=password-generator.php&username=LAB4_DOM_2026

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.12.7 Security Level: 0 (Hosed) Hints: Enabled Logged In User: bee_lab1

Home | Logout | Toggle Hints | Toggle Security | Enforce TLS | Reset DB | View Log | View Captured Data

Password Generator

[Back](#) [Help Me!](#)

[Hints and Videos](#)

Password Generator

Making strong passwords is important.
Click the button below to generate a password.

This password is for LAB4_DOM_2026

Password: g906Kb1c5c4q1bxcH1lMmNgrm1PcpQ8

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application

Q LAB4_DOM_2026

```
<tr></tr>
<tr></tr>
<tr></tr>
<tr style="text-align: center;">
  <td id="idUsernameInput" class="label">
    This password is for LAB4_DOM_2026</td>
  </tr>
  <tr id="idPasswordTableRow" style=""></tr>
  <tr></tr>
  <tr></tr>
</div#id-generator-form-div> > form#idGeneratorForm > table > tbody > tr > td#idUsernameInput.label >
```

Filter Styles

element { }

table tr td.label { }

.label { }

table tr td { }

Layout Computed Changes

Flexbox

Grid

Box Model

margin 0

border 0

At higher sec, the link stopped at generator.php and I added the &user...

https://127.0.0.1/index.php?page=password-generator.php&username=LAB-4 90%

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.12.7 Security Level: 5 (Secure) Hints: Disabled Logged In User: bee_lab1

Home | Logout | Toggle Security | Enforce TLS | Reset DB | View Log | View Captured Data

Password Generator

[Back](#) [Help Me!](#)

Password Generator

Making strong passwords is important.
Click the button below to generate a password.

This password is for LAB-4

Password: ZhQKCDfyKrZvaQ3Ms8ioH4c2v5QaA13

[Generate Password](#)

127.0.0.1/index.php?popupNotificationCode=SL5&page=password-generator.php&username=LAB4

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.12.7 Security Level: 5 (Secure) Hints: Disabled Logged In User: **bee_lab1**

Home | Logout | Toggle Security | Enforce TLS | Reset DB | View Log | View Captured Data

Password Generator

[Back](#) [Help Me!](#)

Password Generator

Making strong passwords is important.
Click the button below to generate a password.

This password is for **LAB-4**
Password: **eths1kmXczVzIoDMffuHcBt11VTaCp2**

Generate Password

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application

1 of 12

Filter Styles

element { }

.ddsmoothmenu ul li a:link, .ddsmoothmenu ul li a:visited { }

color: white; font: bold 12px Verdana;

.ddsmoothmenu ul li ul li a { }

font: normal 13px Verdana; width: 225px; padding: 5px 10px;

padding

margin 0 border 0

pointer inside or press Ctrl+G.

STORED XSS AT HIGHEST

OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.12.7 Security Level: 5 (Secure) Hints: Disabled Logged In User: **bee_lab1**

Home | Logout | Toggle Security | Enforce TLS | Reset DB | View Log | View Captured Data

Welcome To The Blog

[Back](#) [Help Me!](#)

Add New Blog Entry

[View Blogs](#)

Add blog for bee_lab1

Note: , <i> and <u> are now allowed in blog entries

Save Blog Entry

[View Blogs](#)

1 Current Blog Entries

	Name	Date	Comment
1	bee_lab1	2026-09-02 22:51:05	LAB4-STORED-2026


OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.12.7 Security Level: 5 (Secure) Hints: Disabled Logged In User: bee_lab1

[Home](#) | [Logout](#) | [Toggle Security](#) | [Enforce TLS](#) | [Reset DB](#) | [View Log](#) | [View Captured Data](#)

View Blogs

 [Back](#)  [Help Me!](#)

View Blog Entries

 [Add To Your Blog](#)

Select Author and Click to View Blog

Please Choose Author View Blog Entries

1 Current Blog Entries

	Name	Date	Comment
1	bee_lab1	2026-09-02 22:51:05	LAB4-STORED-2026

I CONFIRMED IN A PRIVATE BROWSER

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec


OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.12.7 Security Level: 0 (Hosed) Hints: Enabled Logged In User: bee_lab1

[Home](#) | [Logout](#) | [Toggle Hints](#) | [Toggle Security](#) | [Enforce TLS](#) | [Reset DB](#) | [View Log](#) | [View Captured Data](#)

View Blogs

 [Back](#)  [Help Me!](#)

Hints and Videos

View Blog Entries

 [Add To Your Blog](#)

Select Author and Click to View Blog

Please Choose Author View Blog Entries

1 Current Blog Entries

	Name	Date	Comment
1	bee_lab1	2026-09-02 22:51:05	LAB4-STORED-2026

Want to Help?


[Video Tutorials](#)


[Announcements](#)

OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.12.7 Security Level: 0 (Hosed) Hints: Enabled Logged In User: **bee_lab1**

[Home](#) | [Logout](#) | [Toggle Hints](#) | [Toggle Security](#) | [Enforce TLS](#) | [Reset DB](#) | [View Log](#) | [View Captured Data](#)

Welcome To The Blog

[Back](#) [Help Me!](#)

[Hints and Videos](#)

Add New Blog Entry
[View Blogs](#)

Add blog for bee_lab1

Note: ,<l> and <u> are now allowed in blog entries

Save Blog Entry

[View Blogs](#)

2 Current Blog Entries

	Name	Date	Comment
1	bee_lab1	2026-09-02 23:01:07	TEST AT LOW
2	bee_lab1	2026-09-02 22:51:05	LAB4-STORED-2026

CSRF Protection Information

SESSION MGMT

Sites

Quick Start

Request

Response

Requester

Contexts

Default Context

Sites

https://www.paypalobjects.com

https://fonts.googleapis.com

http://127.0.0.1

http://127.0.0.1:4280

Header: Text

Body: Text

```

GET http://127.0.0.1:4280/login.php HTTP/1.1
host: 127.0.0.1:4280
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Referer: https://127.0.0.1:4280/security.php
Connection: keep-alive
Cookie: security=low; PHPSESSID=f5b9f4d99838e8486a721c06aa470ac0; showhints=1; username=bee_lab1; uid=42
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i

```

History

Search

Alerts

Output

WebSockets

Filter: OFF

Export

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size	Resp. Body	Highest Alert	Note	Tags
399	Pr...	03/09/2026, 00:05:12	POST	http://127.0.0.1:4280/security.php	302	Found	1...	0 bytes		Informati...		SetCookie
400	Pr...	03/09/2026, 00:05:13	GET	http://127.0.0.1:4280/security.php	200	OK	1...	5,257 bytes				AntiCSRF, Form...
401	Pr...	03/09/2026, 00:05:31	GET	http://127.0.0.1:4280/logout.php	302	Found	3...	0 bytes				
402	Pr...	03/09/2026, 00:05:31	GET	http://127.0.0.1:4280/login.php	200	OK	5...	1,388 bytes				AntiCSRF, Form...

Header: Text Body: Text

```

HTTP/1.1 200 OK
Date: Wed, 02 Sep 2026 23:05:31 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 1388
Keep-Alive: timeout=5, max=99
Connection: Keep-Alive
Content-Type: text/html; charset=utf-8

```

```

<!DOCTYPE html>
<html lang="en-GB">
<head>

```

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
399	Pr...	03/09/2026, 00:05:12	POST	http://127.0.0.1:4280/security.php	302 Found	1...	0 bytes		Information...		SetCookie
400	Pr...	03/09/2026, 00:05:13	GET	http://127.0.0.1:4280/security.php	200 OK	1...	5,257 bytes				AntiCSRF, Form...
401	Pr...	03/09/2026, 00:05:31	GET	http://127.0.0.1:4280/logout.php	302 Found	3...	0 bytes				
402	Pr...	03/09/2026, 00:05:31	GET	http://127.0.0.1:4280/login.php	200 OK	5...	1,388 bytes				AntiCSRF, Form...

Before login:

PHPSESSID=f5b9f4d99838e8486a721c06aa470ac0

Login response:

Set-Cookie: PHPSESSID=f5b9f4d99838e8486a721c06aa470ac0

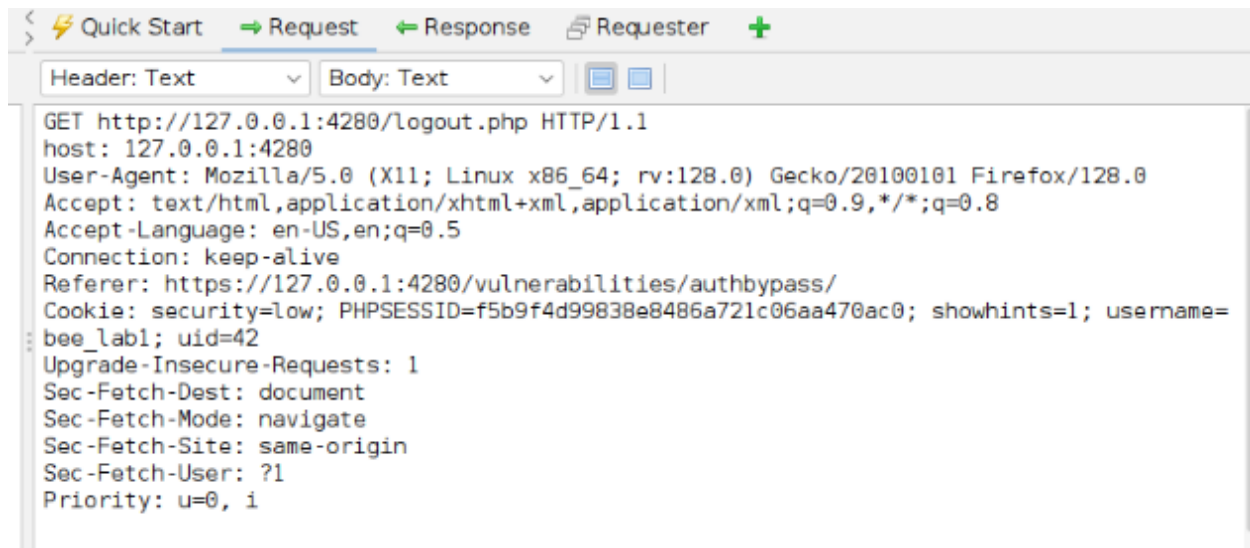
They are identical.

DVWA did not rotate the PHPSESSID after successful authentication.

```
< ⚡ Quick Start → Request ← Response 📄 Requester +
Header: Text Body: Text
POST http://127.0.0.1:4280/login.php HTTP/1.1
host: 127.0.0.1:4280
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Content-Type: application/x-www-form-urlencoded
Content-Length: 88
Origin: https://127.0.0.1:4280
Connection: keep-alive
Referer: https://127.0.0.1:4280/login.php
Cookie: security=low; PHPSESSID=f5b9f4d99838e8486a721c06aa470ac0; showhints=1; username=bee_lab1; uid=42
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
username=admin&password=password&Login=Login&user_token=14dd7e836629e82779bceec5a1b4171a
```

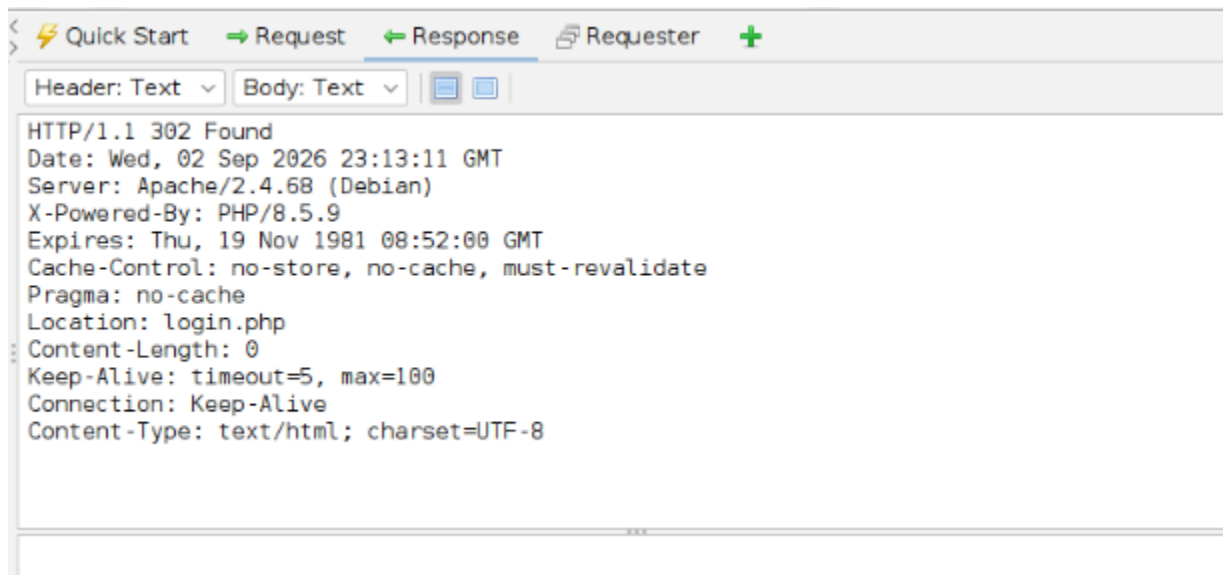
```
< ⚡ Quick Start → Request ← Response 📄 Requester +
Header: Text Body: Text
HTTP/1.1 302 Found
Date: Wed, 02 Sep 2026 23:08:39 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Set-Cookie: PHPSESSID=f5b9f4d99838e8486a721c06aa470ac0; expires=Thu, 03 Sep 2026 23:08:39 GMT; Max-Age=86400; path=/; domain=127.0.0.1
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: index.php
Content-Length: 0
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
```

Logged out on one tab and tried to access index.php on another tab but it took me to the login page instead



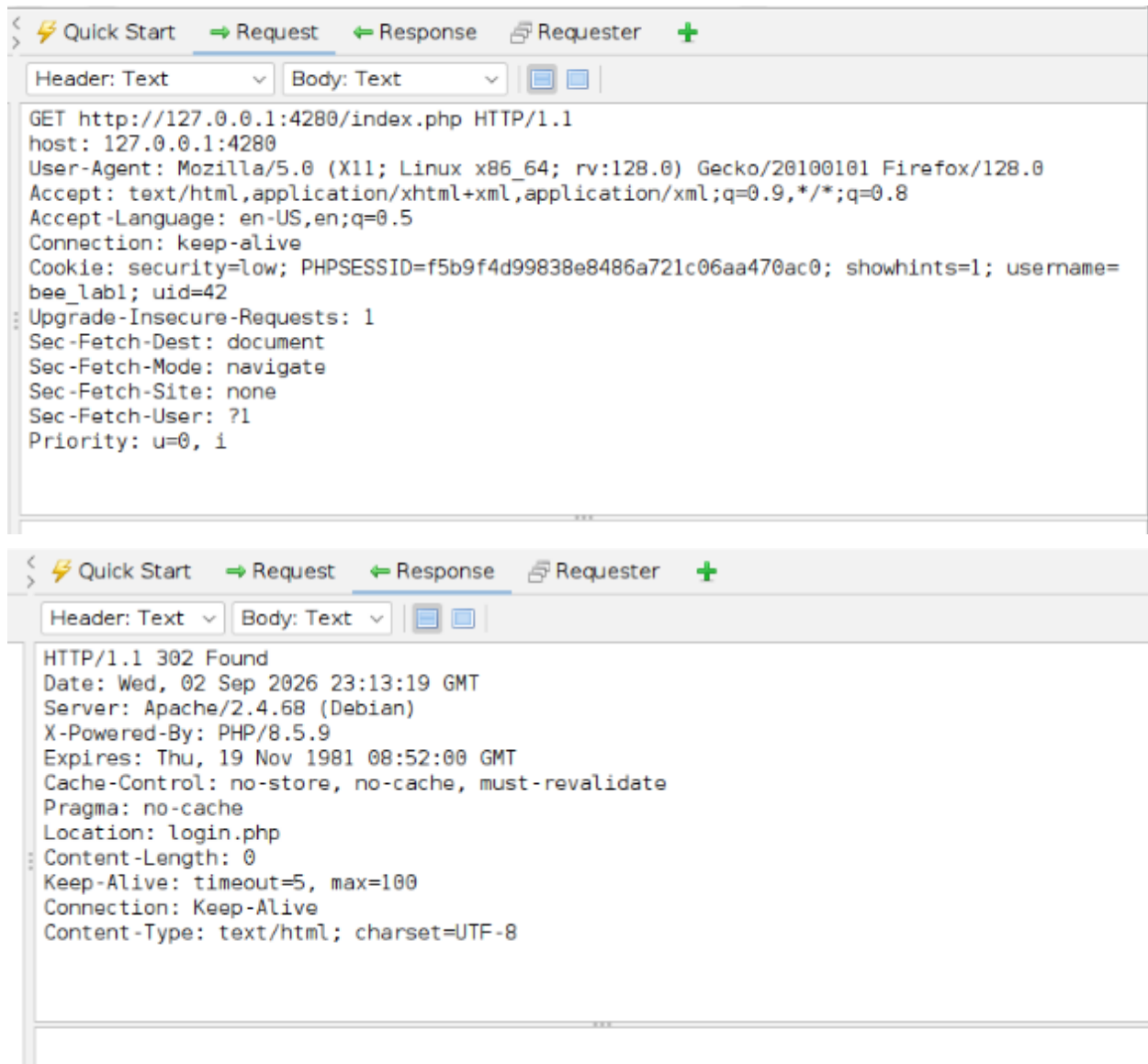
The screenshot shows the 'Request' tab of a web browser's developer tools. The request is a GET to `http://127.0.0.1:4280/logout.php`. The headers include `Host: 127.0.0.1:4280`, `User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0`, `Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8`, `Accept-Language: en-US,en;q=0.5`, `Connection: keep-alive`, `Referer: https://127.0.0.1:4280/vulnerabilities/authbypass/`, `Cookie: security=low; PHPSESSID=f5b9f4d99838e8486a721c06aa470ac0; showhints=1; username=bee_lab1; uid=42`, `Upgrade-Insecure-Requests: 1`, `Sec-Fetch-Dest: document`, `Sec-Fetch-Mode: navigate`, `Sec-Fetch-Site: same-origin`, `Sec-Fetch-User: ?1`, and `Priority: u=0, i`.

```
GET http://127.0.0.1:4280/logout.php HTTP/1.1
host: 127.0.0.1:4280
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: https://127.0.0.1:4280/vulnerabilities/authbypass/
Cookie: security=low; PHPSESSID=f5b9f4d99838e8486a721c06aa470ac0; showhints=1; username=bee_lab1; uid=42
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
```



The screenshot shows the 'Response' tab of a web browser's developer tools. The response is an HTTP 302 Found status. The headers include `HTTP/1.1 302 Found`, `Date: Wed, 02 Sep 2026 23:13:11 GMT`, `Server: Apache/2.4.68 (Debian)`, `X-Powered-By: PHP/8.5.9`, `Expires: Thu, 19 Nov 1981 08:52:00 GMT`, `Cache-Control: no-store, no-cache, must-revalidate`, `Pragma: no-cache`, `Location: login.php`, `Content-Length: 0`, `Keep-Alive: timeout=5, max=100`, `Connection: Keep-Alive`, and `Content-Type: text/html; charset=UTF-8`.

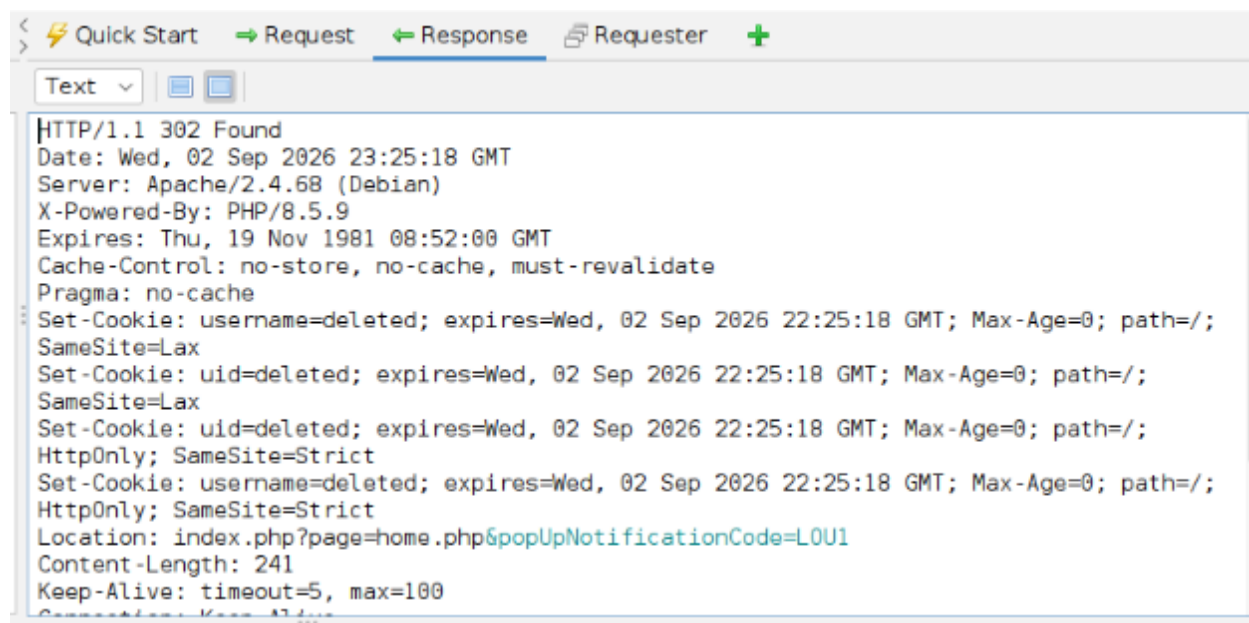
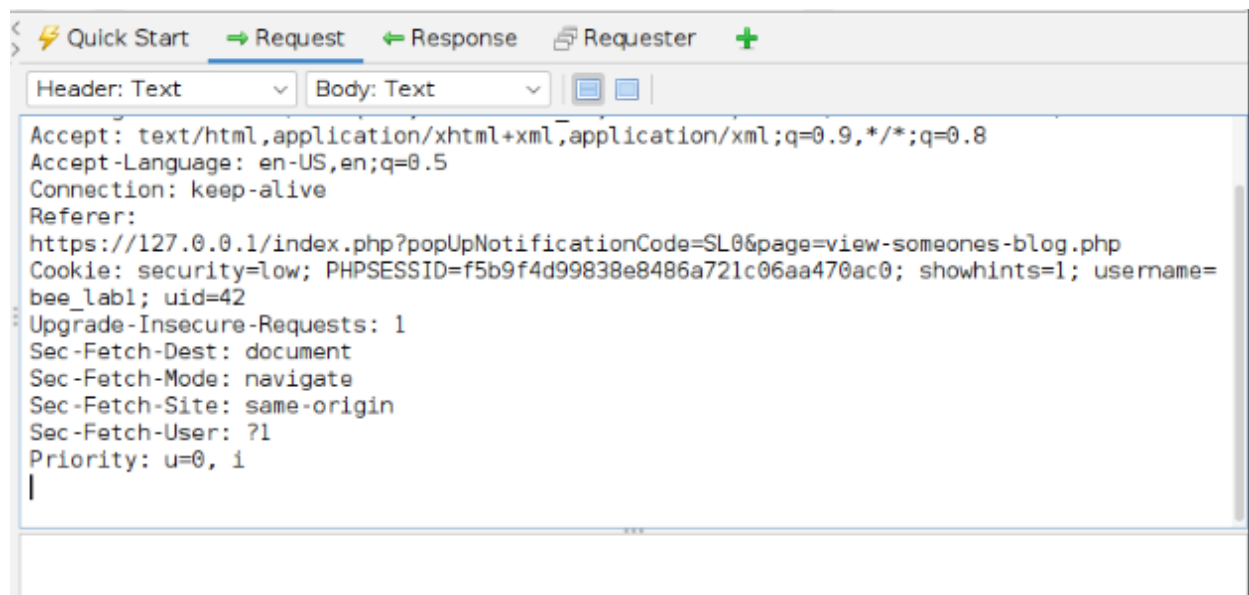
```
HTTP/1.1 302 Found
Date: Wed, 02 Sep 2026 23:13:11 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: login.php
Content-Length: 0
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
```

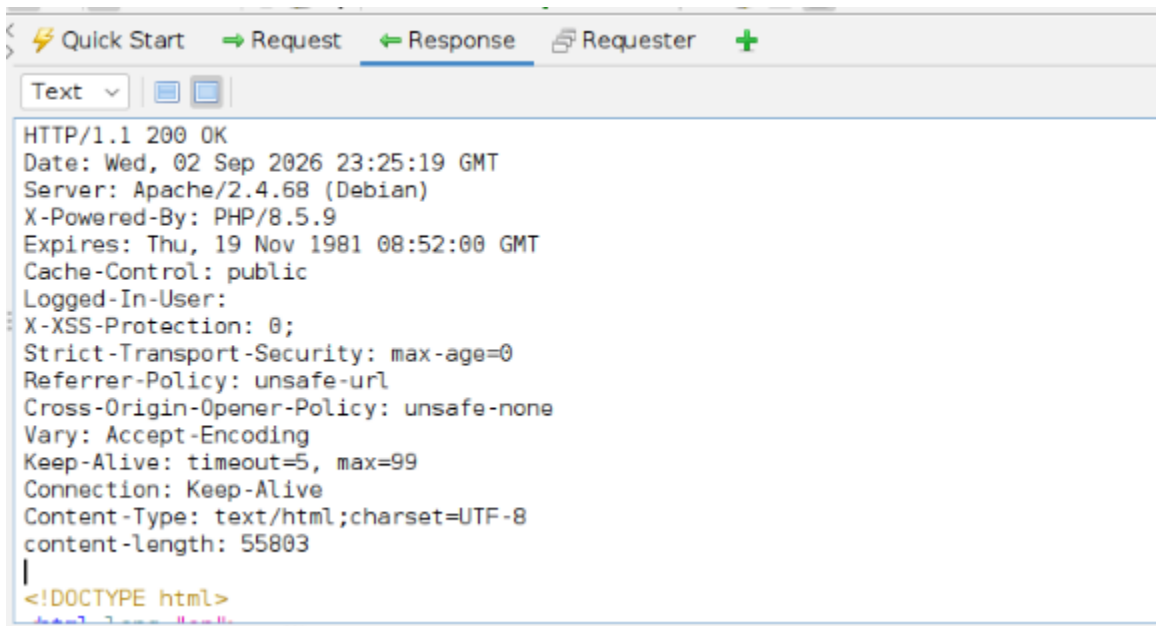
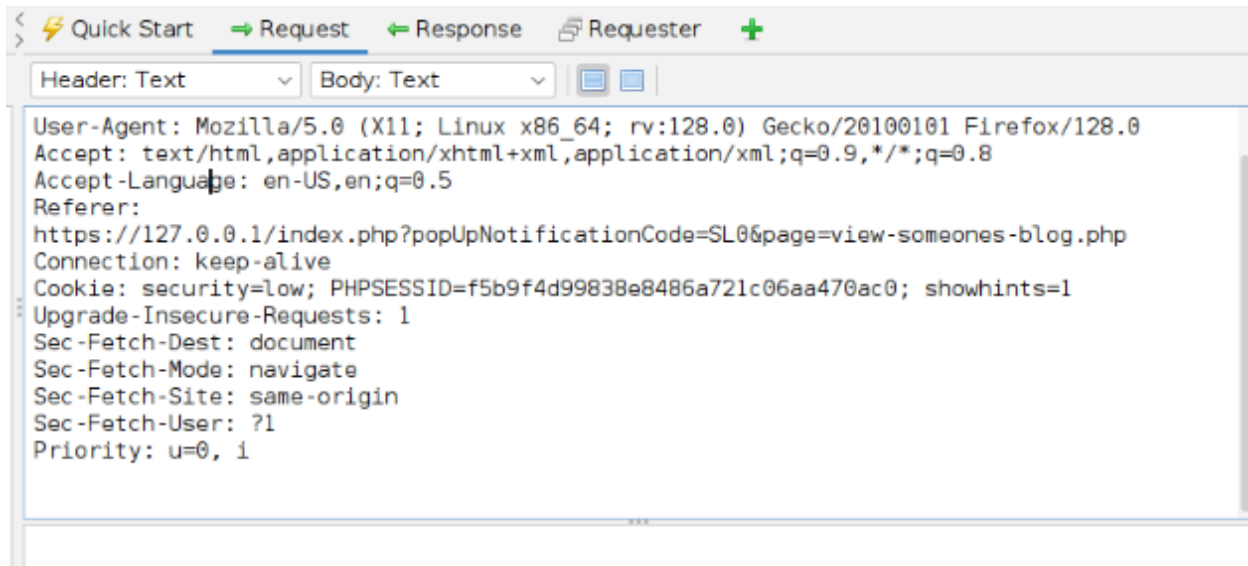


DVWA finding

Authentication resilience weakness: No observable lockout or rate-limiting after 5 consecutive failed login attempts.

MULTILLIDAE SESSION MANAGEMENT





Quick Start

Request

Response

Requester

+

Header: Text

Body: Text

POST http://127.0.0.1/index.php?page=login.php HTTP/1.1

host: 127.0.0.1

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

Accept-Language: en-US,en;q=0.5

Content-Type: application/x-www-form-urlencoded

Content-Length: 79

Origin: https://127.0.0.1

Connection: keep-alive

Referer: https://127.0.0.1/index.php?page=login.php

Cookie: security=low; PHPSESSID=f5b9f4d99838e8486a721c06aa470ac0; showhints=1

Upgrade-Insecure-Requests: 1

Sec-Fetch-Dest: document

Sec-Fetch-Mode: navigate

Sec-Fetch-Site: same-origin

Sec-Fetch-User: ?1

Priority: u=0 i

redirectPage=&username=bee_lab1&password=password&login-php-submit-button=Login

Sockets

+

Quick Start

Request

Response

Requester

+

Text

HTTP/1.1 302 Found

Date: Wed, 02 Sep 2026 23:36:42 GMT

Server: Apache/2.4.68 (Debian)

X-Powered-By: PHP/8.5.9

Expires: Thu, 19 Nov 1981 08:52:00 GMT

Cache-Control: no-store, no-cache, must-revalidate

Pragma: no-cache

Set-Cookie: username=bee_lab1; path=/; SameSite=Lax

Set-Cookie: uid=42; path=/; SameSite=Lax

Location: index.php?popUpNotificationCode=AU1

Content-Length: 0

Keep-Alive: timeout=5, max=100

Connection: Keep-Alive

Content-Type: text/html; charset=UTF-8

Sockets

+